codigo

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Aqui está a análise detalhada, passo a passo, do arquivo `codigo.py`:

1. Análise Passo a Passo do Código

A. Verificação de Privilégios e Preparação do Ambiente

O que faz: No início da função `main()`, o script verifica se é executado com privilégios de superusuário (`os.geteuid() != 0`). Caso não seja `root`, ele falha. Se for, ele atualiza os repositórios do sistema e instala ferramentas de rede e utilitários de sistema de forma automatizada (`masscan`, `python3-pip`, `python3-venv`, `screen`, `libpcap-dev`, `curl`).

Avaliação: Comportamento típico de instaladores de rootkits ou ferramentas de infraestrutura maliciosa que exigem controle total do sistema operacional.

B. Criação de Serviços Persistentes (`systemd`)

O que faz: O script cria e ativa dois serviços no sistema (`systemd`):

1. `scan-runner.service`: Executa continuamente um script de varredura (`run_scan.sh`).
2. `file-monitor.service`: Executa um script de monitoramento (`monitor_script.py`) em segundo plano dentro de um ambiente virtual Python (`venv`).

Avaliação: Garante **persistência**, assegurando que as atividades maliciosas continuem rodando mesmo após reinicializações do servidor.

C. Varredura de Rede em Massa (`Masscan` + `ssh_scanner.py`)

O que faz:

Baixa listas de endereços IP externos de uma URL remota (`[https://del.sou.pp.ua/ip_ranges.txt](https://del.sou.pp.ua/ip_ranges.txt)`).

Utiliza a ferramenta `masscan` para escanear a internet/redes em busca de portas SSH abertas (especificamente nas portas `22` e `5522`).

Usa um scanner multi-thread em Python (`ssh_scanner.py` com a biblioteca `paramiko`) para realizar **ataques de força bruta** utilizando credenciais predefinidas (`LeitboGi0ro` , `123@@@`).

Avaliação: Atividade de varredura automatizada de portas e força bruta de credenciais (recurso clássico de propagação de worms).

D. Propagação Autônoma e Comunicação Externa (C2)

O que faz: Através do `monitor_script.py` , o sistema verifica se encontrou servidores vulneráveis. Quando obtém sucesso em um acesso SSH:

Copia a si mesmo (`codigo.py` renomeado como `bendi.py`) para o servidor remoto (`/tmp/bendi.py`).

Executa o código remotamente para infectar a nova máquina.

Instala um agente de monitoramento de terceiros vindo de um repositório externo do GitHub (`komari-agent`).

Comunica-se com um servidor de comando e controle centralizado (`sou.pp.ua`) para registrar IPs processados e evitar duplicações.

Envia relatórios detalhados de infecção em tempo real para um **Bot do Telegram** configurado com token e chat ID fixos no código.

Avaliação: Comportamento evidente de um **Worm (Verme de Computador)** auto-propagável com funcionalidade de exfiltração de telemetria para canais de chat públicos/criptografados.

E. Autolimpeza (Anti-forense)

O que faz: Ao finalizar a configuração inicial bem-sucedida, o script executa um comando para apagar a si mesmo do disco (`rm -- '{this_script_path}'`).

Avaliação: Técnica comum usada por malwares para dificultar a análise pós-infecção e apagar rastros imediatos.

2. Conclusão Definitiva

Este arquivo NÃO é benigno; trata-se de um MALWARE.

Especificamente, é um **Worm de Propagação Automatizada e Botnet Scanner** projetado para:

1. Escalar privilégios e persistir no sistema hospedeiro.
2. Realizar varreduras agressivas de rede (`masscan`) e força bruta SSH.
3. Infectar automaticamente novos servidores encontrados.
4. Comunicar-se com servidores de Comando e Controle (C2) e reportar infestações via Telegram.

Qual é a categoria principal deste malware?

A categoria principal deste malware é a de um **Worm de rede (verme de propagação autónoma)**, combinado com funcionalidades de **Botnet** e **Scanner de Força Bruta**.

As características que definem esta categorização incluem:

Autopropagação (Worm): O código possui a capacidade intrínseca de se replicar e espalhar automaticamente. Ele realiza varreduras de rede à procura de portas abertas, executa ataques de força bruta SSH em servidores desprotegidos e copia-se a si mesmo para infetar novos alvos.

Componente de Botnet e Comando e Controlo (C2): Comunica-se com servidores centrais externos para gerir os alvos processados e reporta o sucesso das invasões em tempo real através de um Bot do Telegram, permitindo o controlo remoto automatizado da infraestrutura infetada.